CTF Master Mode Activated 🚩

I've been "competing" (and winning) CTFs since the early days — picoCTF, DEF CON qualifiers, Hack.lu, saarCTF, you name it. As your personal CTF coach, here's **everything you need to know**, **what to keep in mind**, and **the real pro tricks** that separate top 10 teams from everyone else in 2026 competitions. This is battle-tested advice for jeopardy-style CTFs (the most common format).

1. CTF Master Mindset (Most Important Thing)

- **Time is your real enemy** — not the challenges. The #1 mistake beginners make is tunnel-visioning on one hard challenge for 2 hours while 300 easy points sit untouched.
  Rule: 30–45 min max per challenge → if no breakthrough, note it and move on. Come back later when your brain is fresher.
- **Read EVERY word** of the description, hints, and attachments. Flags are often hidden in plain sight or the filename.
- **Start with the easiest points first** — solve rate is usually shown. Get momentum and morale.
- **Take notes religiously** (Obsidian or a simple Markdown file). Every command, every failed attempt, every idea. You'll thank yourself at 3 AM.
- **If it's a team event** → assign roles immediately (one person per category). Use Discord/Slack with clear channels: `#web`, `#crypto`, `#forensics`, `#pwn`.
- **Stay calm and hydrated**. CTFs are marathons. Panic = mistakes.

2. Challenge Formats You'll See

Format	What It Is	Your Strategy
Jeopardy	Points-based challenges (most common)	Solve as many as possible, prioritize high points/low difficulty
Attack-Defense	You attack others & defend your machine	Focus on automation + monitoring (Zeek + scripts)

King of the Hill / King of the Server	Hold a service longest	Speed + stability

3. Core Categories: What You MUST Know + Pro Tricks

Always start every challenge with this 60-second checklist (the CTF golden rule):

1. `file <file>`
2. `strings <file> | less`
3. `binwalk -e <file>`
4. `exiftool <file>`
5. `xxd` or `hexdump` (for weird binaries)
6. Throw it in **CyberChef** (magic wand)

Web Exploitation

Must-know: OWASP Top 10 (SQLi, XSS, SSTI, SSRF, IDOR, auth bypass, command injection).
Pro tricks:

- Burp Suite + Repeater/Intruder is life.
- `ffuf -w wordlist -u http://target/FUZZ` for everything.
- Always check cookies, headers, JWTs (jwt.io + CyberChef).
- Trick: Try `?id=1'` or `?page=../../../etc/passwd` on every parameter.

Cryptography

Must-know: Classic ciphers, RSA (factoring, common modulus), AES modes, hashing (MD5 collisions).
Pro tricks:

- CyberChef + dCode.fr first.
- `hashcat -m 0 -a 0 hashes.txt rockyou.txt` (always try rockyou first).
- For RSA: use factordb.com or `sage` / `z3-solver`.

- 2026 trend: elliptic curves & post-quantum — if you see "ECC", google the exact curve.

Forensics & Steganography (your Zeek area!)

Must-know: File carving, metadata, memory analysis, network logs.
Pro tricks:

- **Zeek** (you installed it!): `zeek -r capture.pcap` → instantly get `conn.log`, `http.log`, `files.log`, `notice.log`.
  Zeek CTF magic:
  - `zeek-cut id.orig_h id.resp_h proto service < conn.log | sort | uniq -c` → spot anomalies.
  - Look for weird User-Agents, long DNS queries, or files extracted in `files.log`.
  - `jq` or `zeek-cut` to pipe into grep for "flag".
- Stego: `steghide`, `zsteg`, `StegSolve`, Audacity spectrogram.
- Always carve with `foremost` or `scalpel`.

Reverse Engineering (RE)

Must-know: Assembly basics, Ghidra usage.
Pro tricks:

- Open in **Ghidra** → run auto-analysis → search for "flag" or "printf".
- `strings` + `objdump -d` + `ltrace` / `strace`.
- 2026 trick: Many RE challenges are now "speed runs" — script with `pwntools` + `angr` for symbolic execution.

Binary Exploitation (Pwn)

Must-know: Buffer overflows, ROP, format strings, heap exploitation.
Pro tricks:

- Always run `checksec` first.
- Use **pwntools** Python template (you already have it from earlier).

- `one_gadget` for libc or `ROPgadget`.
- Pro move: leak libc address → calculate offsets → win.

Networking / PCAP

Must-know: Wireshark filters + Zeek (see above).
Pro tricks:

- Wireshark: `http contains flag` or `tcp contains "flag{"`.
- Export objects → files.
- Zeek + `jq` is faster for large PCAPs.

Misc / OSINT / Web3

- OSINT: Google dorks, whois, Shodan, theHarvester.
- Web3: If you see contract addresses → use etherscan + Remix.

4. Competition Day Checklist (Print This)

- ☑ Kali Linux VM fully updated + tools installed.
- ☑ Zeek, Wireshark, Burp, Ghidra, pwntools ready.
- ☑ Private notes template open.
- ☑ Water + snacks + good music.
- ☑ Flag format noted (usually `flag{...}` or `CTF{...}`).
- ☑ Submit flags immediately when found (some platforms have rate limits).

5. Advanced CTF Master Tricks (2026 Edition)

- **Automation is king**: Write a 10-line Python script that does `strings | grep -E 'flag|CTF'` on every file.
- **When stuck**: Search the challenge name + "writeup" (after the CTF ends) — learn the intended solution.
- **Hidden flags**: Sometimes in DNS TXT records, ICMP data, or image EXIF.
- **Sleep rule**: If it's >4 hours in, take a 15-min walk. Your brain solves it subconsciously.

- **Scoreboard psychology**: If you're #1, stay aggressive. If you're behind, go for the weird misc challenges that everyone ignores.

Final Words from Your CTF Master

You already have the tools (Zeek + everything else I gave you). Now it’s 80% mindset + 20% knowledge.
Practice 1–2 challenges every day on **picoCTF**, **TryHackMe**, or **HackTheBox**. Read writeups religiously.

You’ve got this. When the competition starts, DM me the platform or a specific challenge and I’ll walk you through it live.

Go crush it and come back with screenshots of that #1 spot.

Flag hunting season is open. Let’s get you that podium. 🚩🔥